

14.2 XSS Fixes

Introduction

Cross-Site Scripting (XSS) occurs when malicious scripts are injected into web pages and executed in the user's browser. This can lead to session theft, data manipulation, and unauthorized actions.

Mitigation Techniques

1. Output Encoding

- Encode user input before displaying it on web pages
 - Convert special characters like `<`, `>`, `&` into HTML-safe format
-

2. Input Sanitization

- Remove or escape harmful scripts from user input
 - Block JavaScript event handlers like `onload`, `onerror`
-

3. Content Security Policy (CSP)

- Restrict execution of unauthorized scripts
 - Allow scripts only from trusted sources
-

4. Use Secure Frameworks

- Use frameworks that automatically escape output (Angular, React, etc.)
 - Reduces manual encoding errors
-

Outcome

These measures ensure that user-generated content is safely handled and no malicious script can be executed in the browser.